Lab 5: Static Code Analysis

Name:Pallavi Rajkumar Bubanale

SRN:PES1UG24CS314

Reflection Answers

Note: These questions are based on the reflection questions currently drafted in the project issues.md file. Check them against the exact questions in your lab instructions before submitting.

1. What is static code analysis?

Static code analysis is the process of checking source code without running the program. It helps identify possible bugs, security weaknesses, and coding-style problems early. In this lab, Pylint, Bandit, and Flake8 were used to examine the Python program.

2. What is the difference between Pylint, Bandit, and Flake8?

Pylint checks code quality, naming, documentation, and common programming mistakes. Bandit looks for common security issues in Python code. Flake8 checks style and formatting and reports certain code-quality problems. Using all three provides different types of feedback.

3. What challenges did you face while fixing the issues?

One challenge was understanding why a reported pattern could cause a problem and choosing a fix without changing the program's intended behaviour. For example, input validation needed to handle invalid seat numbers, and file handling needed to be safer. After making changes, the tools had to be run again to check that the reported issues were resolved.

4. How does static code analysis improve software quality and maintainability?

Static code analysis helps detect issues early, encourages consistent coding practices, and can reduce security risks. Clear naming, useful docstrings, safer exception handling, and consistent formatting make code easier to understand and maintain. Re-running the tools after changes also helps verify the fixes.

Tools used: Pylint, Bandit, and Flake8